RESTRICTED

QAYRAWAN INFORMATION SYSTEMS

Data Protection Policy

Organizational policy · ECC Compliance Program

Document ID	**QIS-POL-001**
Version	0.4 (Draft)
Date	11 November 2026
Classification	Restricted
Sharing signal	Amber · TLP:AMBER

Prepared by Naif Alsalem, GRC Lead

Issued in Arabic and English; if they conflict, the Arabic text prevails. QIS is a fictional company: its people and clients are invented for a professional portfolio by Naif Alsalem. The regulators and regulations cited are real.

RESTRICTED

Policy information

Policy name	Data Protection Policy
Policy code	QIS-POL-001
Policy owner	GRC Lead — Naif Alsalem
Prepared by	Naif Alsalem — GRC Lead
Date created	5 November 2026
Policy version	0.4 (Draft)
Implementing procedures	QIS-PRC-001 Data Protection Procedure

Sharing signal (Traffic Light Protocol)

This policy is marked under the Traffic Light Protocol (TLP) used in National Cybersecurity Authority documents at **Amber (TLP:AMBER)**. It may not be circulated beyond that level without the owner's approval.

● **Red** TLP:RED	Personal and confidential to the recipient only: it may not be shared with anyone inside or outside the recipient's organization beyond the stated recipients.
● **Amber** TLP:AMBER	**Limited sharing: the recipient may share it within their own organization, only with the people concerned and those who need to act on it. — the level set for this document**
● **Green** TLP:GREEN	Sharing within the same community: it may be shared within the organization, related organizations or the same sector, but not through public channels.
● **White** TLP:WHITE	Unlimited.

RESTRICTED

Change log

Version	Date	Changed by	Reason for change
0.1	5 Nov 2026	Naif Alsalem	First draft: eleven clauses with performance and risk indicators.
0.2	10 Nov 2026	Naif Alsalem	Rebuilt on QIS's policy template; clauses mapped to the Essential Cybersecurity Controls and the Data Cybersecurity Controls; PDPL alignment added; implementing steps moved to QIS-PRC-001; new visual identity.
0.3	10 Nov 2026	Naif Alsalem	Section 8 matched to the official ECC-2:2024 text: subdomain 2-7 cut to three controls, the National Cryptographic Standards added to 2-8-3, cybersecurity outsourcing added to 4-1, and in-Kingdom hosting removed from the text of 4-2-3 and kept as a QIS requirement on its current basis. English version translated from the Arabic lead text.
0.4	11 Nov 2026	Naif Alsalem	Section 8 objectives and controls quoted word for word from the official English text of ECC-2:2024, with their sub-controls, including the missing parts of 4.1.2.3, 4.1.3.1, 4.1.3.2 and 4-2-3.

RESTRICTED

Document approval

Role	Job title	Name	Date	Signature
Owner	GRC Lead	Naif Alsalem	—	—
Reviewer	Chief Technology Officer	Reem Al-Otaibi	—	—
Reviewer	Head of Service Delivery	Sultan Al-Dossary	—	—
Reviewer	Chief Financial Officer (contracts and HR)	Majed Al-Qahtani	—	—
Endorser	Chair, Cybersecurity Steering Committee	Faisal Al-Harbi	—	—
Approver	Chief Executive Officer	Faisal Al-Harbi	—	—

Review schedule

Review frequency	Last review	Next review
Annually, or when laws and regulations, QIS's services or a data incident require it	—	November 2027

RESTRICTED

Policy classification

Top Secret	The policy is classified "Top Secret" if unauthorized access to it or disclosure of it or its content would cause serious damage that cannot be remedied or repaired.
Secret	The policy is classified "Secret" if unauthorized access to it or disclosure of it or its content would cause serious damage. This applies to sensitive information that defines how QIS operates.
Restricted	**The policy is classified "Restricted" if unauthorized access to it or disclosure of it or its content would cause limited damage. This applies to information not approved for general circulation outside QIS.**
Public	The policy is classified "Public" when unauthorized access to it or disclosure of its content would have no effect on QIS. This applies to documents approved for public release.

Confidentiality of the policy

This policy is a Qayrawan Information Systems document classified Restricted. It may be circulated only to QIS staff and to the government clients under contract who need to see it. It may not be published, changed or shared, in whole or in part, with anyone unauthorized without the prior written approval of the policy owner.

RESTRICTED

Contents

1. Terms and definitions
2. Introduction
3. Purpose
4. Scope
5. Compliance with the policy
6. Roles and responsibilities
    6.1 Responsibility matrix (RACI) · 6.2 QIS's role and the personal data protection officer
7. Principles
8. Policy clauses — Essential Cybersecurity Controls and Data Cybersecurity Controls
9. Alignment with the Personal Data Protection Law
10. Key performance indicators (KPIs)
11. Key risk indicators (KRIs)
12. Consequences of non-compliance
13. Contact
14. Review and update
15. References

RESTRICTED

1. Terms and definitions

Term	Definition
Data	Facts in raw or unorganized form, such as numbers, letters and images, in any form: electronic or paper.
Client data	Any data belonging to Clients A to F that QIS processes, hosts or accesses under a contract, whatever its classification.
Personal data	Any data that identifies an individual directly or indirectly, such as citizen records in Client A's portal and student records at Client C.
Controller	The party that decides the purpose and means of processing personal data. For data QIS processes on its behalf, this is the government client.
Processor	The party that processes personal data for and on behalf of the controller. For the services it provides to clients, this is QIS.
Data owner	The person or department that sets the data's classification and approves access to it and sharing of it. For client data, this is the client.
Classification levels	Top Secret, Secret, Restricted and Public, under the national data classification levels.
Third party	Any organization that provides QIS with services or products and has access to its data or its clients' data, including the cloud provider and contractors.
Screening / vetting	Checking a person's background and trustworthiness before granting access to data.
Data masking	Replacing sensitive values with realistic but false ones that keep their format, for use in development, testing or sharing.
Data scrambling	Reordering or mixing data values so they cannot be linked to the people they describe.
Closed room	A dedicated, access-controlled workspace for processing data from highly sensitive projects.
Data breach	Any unauthorized access to, disclosure, change, loss or destruction of data, actual or suspected.
Secure disposal	Removing data from storage media so it cannot be recovered, documented by a disposal certificate.
Data loss prevention (DLP)	Technology that stops sensitive data leaving QIS through unauthorized channels.
Key performance indicator (KPI)	A measure of how well targets are met and how processes and controls perform.

RESTRICTED

Term	Definition
Key risk indicator (KRI)	A measure that gives early warning when a risk approaches the limits of risk appetite.
Policy	An approved, formal document setting the principles and rules that govern how QIS works.
Procedure	An implementing document under a policy that sets the steps, owner, outputs, time limits and records for a piece of work.

2. Introduction

Qayrawan Information Systems provides managed IT, hosting and software development services to six government clients, and processes classified data and the personal data of citizens and students on their behalf. It works with contractors and a cloud provider. Data is the core of what clients entrust to QIS, so any breach damages their trust, QIS's reputation and its ability to meet its legal and contractual duties.

3. Purpose

This policy protects the data QIS owns or processes for its clients across its whole life cycle, from collection, processing, storage, transfer and sharing to retention and disposal, so that it stays confidential, intact and available, including when third parties handle it.

Its clauses are built on the Essential Cybersecurity Controls (ECC-2:2024) and the Data Cybersecurity Controls (DCC-1:2022) issued by the National Cybersecurity Authority, the Personal Data Protection Law and its implementing regulation, and QIS's contractual duties to its clients.

4. Scope

- All data QIS owns or processes for Clients A to F, in any form: electronic or paper.
- All systems and assets within the program scope (QIS-PRF-001), including hosted systems and the citizen portal.
- All staff and contractors in Riyadh and Jeddah.
- All third parties with access to QIS data or client data, including the cloud provider.
- Every stage of the data life cycle: collection, processing, storage, transfer, sharing, retention and disposal.

RESTRICTED

5. Compliance with the policy

The GRC Lead must ensure QIS complies with this policy, and every department concerned must apply it. Its clauses are carried out through the detailed procedures in QIS-PRC-001. Where they conflict, this policy prevails, then the applicable laws and regulations, then the strictest contractual duty.

6. Roles and responsibilities

Role	Responsibilities
Chief Executive Officer	Approves the policy, provides the resources to apply it, approves exceptions, and signs contracts that contain data protection requirements.
Cybersecurity Steering Committee	Endorses the policy, follows its indicators every quarter, escalates red indicators, and approves highly sensitive projects.
GRC Lead (personal data protection officer)	Owns and updates the policy, monitors compliance, reviews security requirements in contracts, coordinates with controllers, and reports the indicators.
Security Operations and Engineering	Runs and monitors data loss prevention, checks screening results, and leads the response to data breaches.
Chief Technology Officer	Applies the technical controls: encryption, access control, environment separation, secure disposal and management of the cloud provider.
Head of Service Delivery	Applies the policy in managed services, passes on clients' documented instructions about their data, and notifies them of incidents.
Chief Financial Officer	Puts data protection and confidentiality clauses into contracts, follows contractor screening with HR, and ends access when people leave.
Independent auditor	Checks every year that the policy is applied and its controls work.
All staff and contractors	Follow the policy, handle data according to its classification, and report any actual or suspected breach at once.

6.1 Responsibility matrix (RACI)

CEO: Chief Executive Officer · Committee: Cybersecurity Steering Committee · GRC: Governance, Risk and Compliance · SecOps: Security Operations and Engineering · CTO: Chief Technology Officer · Delivery: Service Delivery · CFO: Chief Financial Officer

R — Responsible · A — Accountable · C — Consulted · I — Informed

RESTRICTED

Activity	CEO	Committee	GRC	SecOps	CTO	Delivery	CFO
Approving the policy and its updates	A	C	R	C	C	C	C
Classifying data and documenting it	I	I	A	C	R	R	I
Security requirements in contracts	A	I	R	C	C	C	R
Screening third parties	I	I	C	A	I	I	R
Granting access to data and sharing it	I	I	C	A	R	C	I
Encryption and key management	I	I	C	C	A/R	I	I
Responding to and reporting breaches	I	I	R	A/R	R	R	I
Secure disposal and return of data	I	I	C	C	A/R	R	I
Measuring the indicators (KPIs / KRIs)	I	C	A/R	C	C	C	I

6.2 QIS's role and the personal data protection officer

Added clause — Qayrawan Information Systems

This clause does not appear in this form in the reference documents. It was added because QIS is a processor for its clients and a controller for its own data, and does not yet have a separate data protection function.

QIS-ORG-1	QIS acts as processor for client data, so it processes that data only under the contract and the controller's documented instructions. It acts as controller for the data of its own staff and contractors.
QIS-ORG-2	The GRC Lead acts as personal data protection officer until a separate officer is appointed. This role is kept separate from running the systems that process the data.
QIS-ORG-3	The RACI is updated when a Head of Cybersecurity or a separate data protection officer is appointed, and an update to this policy records it.

RESTRICTED

7. Principles

7.1 Processing on instructions

Client data is processed for the purpose set in the contract and only on the controller's documented instructions, and is used for nothing else.

7.2 Minimum necessary

Data is collected, made available and shared only as far as the purpose needs, and is reduced to the lowest classification that serves the purpose before it is shared.

7.3 Data sovereignty

Client data is stored and processed inside Saudi Arabia, and leaves the Kingdom only where the law allows and the controller agrees.

7.4 Protection across the life cycle

Controls are applied according to the data's classification at every stage, from collection to secure disposal.

7.5 Accountability

Every data set has a named owner, and every access to it or sharing of it is recorded and traceable.

8. Policy clauses — Essential Cybersecurity Controls and Data Cybersecurity Controls

QIS complies with the Essential Cybersecurity Controls (ECC-2:2024) in the subdomains below, and alongside them applies the Data Cybersecurity Controls (DCC-1:2022) that fit an organization processing government data. Each subdomain shows its controls, then the additional requirements QIS sets.

2 Cybersecurity Defense

The 2024 edition of the controls removed the sub-items on data ownership, classification, labelling and privacy, and referred data privacy to the National Data Management Office. QIS keeps its own requirements on these points in its implementation requirements below.

2-7 Data and Information Protection

Objective: To ensure confidentiality, integrity, accuracy, and availability of the entity’s data and information, as per the entity’s regulatory policies and procedures and the relevant legislative and regulatory requirements.

RESTRICTED

No.	Controls
2-7-1	Cybersecurity requirements for protecting and handling data and information of the entity shall be identified, documented, and approved, as per the relevant legislative and regulatory requirements.
2-7-2	Cybersecurity requirements for protecting data and information of the entity shall be implemented, based on its classification level.
2-7-3	The implementation of cybersecurity requirements for protecting data and information of the entity shall be periodically reviewed.

Additional implementation requirements — Qayrawan Information Systems

QIS-2-7-1	Client data is classified using the client's own classification, and QIS data using the national classification levels. No system holding Restricted data or higher is put into operation before its classification and owner are documented.
QIS-2-7-2	Storage, transfer, sharing and disposal rules apply by classification level, as in Table 8-1.
QIS-2-7-3	A record of personal data processing activities is kept for each client, covering purpose, categories, retention period and who can access the data.
QIS-2-7-4	Real personal data may not be used in development or test environments. Masked or synthetic data is used instead, except with the written approval of the controller and the GRC Lead.
QIS-2-7-5	Data loss prevention covers email, cloud storage and endpoints, and its alerts are reviewed daily.
QIS-2-7-6	Data is kept for the period set by the contract or the law, whichever is longer, then securely disposed of, with a disposal certificate for Restricted data and higher.

RESTRICTED

Table 8-1: Data handling rules by classification

Level	Storage	Transfer	Sharing	Disposal
Top Secret and Secret	Inside the Kingdom, encrypted, on isolated systems with the client's permission	Encrypted, with the client's written approval	Not allowed without the controller's written approval	Secure disposal with a certificate
Restricted	Inside the Kingdom, encrypted at rest	Always encrypted	To those who need it for their work, under a contract	Documented secure disposal
Public	No special restrictions	No special restrictions	Allowed	Normal deletion

2-8 Cryptography

Objective: To ensure the proper and efficient use of cryptography to protect electronic information assets of the entity, as per the entity's regulatory policies and procedures and the relevant legislative and regulatory requirements.

No.	Controls
2-8-1	Cybersecurity requirements for cryptography within the entity shall be identified, documented, and approved.
2-8-2	Cybersecurity requirements for cryptography within the entity shall be implemented.
2-8-3	Cybersecurity requirements for cryptography shall include at least the requirements in the National Cryptographic Standards, published by NCA. The appropriate cryptographic standard level shall be implemented based on the nature and sensitivity of the data, systems, and networks to be protected as well as the entity's risk assessment, and as per the relevant legislative and regulatory requirements, as follows: **2.8.3.1** Approved cryptographic systems and solutions standards and their technical and regulatory restrictions. **2.8.3.2** Secure management of cryptographic keys during their lifecycles. **2.8.3.3** Encryption of data in-transit and at-rest, as per their classification and the relevant legislative and regulatory requirements.
2-8-4	The implementation of cybersecurity requirements for cryptography within the entity shall be periodically reviewed.

Additional implementation requirements — Qayrawan Information Systems

QIS-2-8-1	Data in transit across networks is encrypted with TLS 1.2 or later. Unencrypted protocols may not be used to transfer client data.
QIS-2-8-2	Data classified Restricted or higher is encrypted at rest, in line with the National Cryptographic Standards.
QIS-2-8-3	Encryption keys are kept apart from the data they protect, in a managed key vault, and are rotated at least once a year and at once if exposure is suspected.

4 Third-Party and Cloud Computing Cybersecurity

QIS sits on both sides of these controls: it is a third party to its government clients, and it also works with third parties that have access to its data and its clients' data. The requirements below apply to both.

4-1 Third-Party Cybersecurity

Objective: To ensure the protection of the entity's assets against third-party cybersecurity risks (including Information Technology (IT) outsourcing, cybersecurity outsourcing, and

RESTRICTED

managed services), as per the entity's regulatory policies and procedures and the relevant legislative and regulatory requirements.

No.	Controls
4-1-1	Cybersecurity requirements for the entity's contracts and agreements with third parties shall be identified, documented, and approved.
4-1-2	Cybersecurity requirements for contracts and agreements with third parties, e.g. Service Level Agreement (SLA), which, if impaired, may affect the entity's data or services shall include the following as a minimum: **4.1.2.1** Clauses of non-disclosure and the secure removal of the entity's data by the third party upon the end of service. **4.1.2.2** Communication procedures in case of the occurrence of a cybersecurity incident. **4.1.2.3** Obligating the third party to apply the entity's cybersecurity requirements and policies and the relevant legislative and regulatory requirements.
4-1-3	Cybersecurity requirements for contracts and agreements with third parties providing IT or cybersecurity outsourcing or managed services shall include the following as a minimum: **4.1.3.1** Conducting a cybersecurity risk assessment and ensuring the availability of risk mitigation controls before signing contracts and agreements or upon making changes to the relevant legislative and regulatory requirements. **4.1.3.2** Cybersecurity managed service centers for monitoring and operations which use remote access shall be fully located in the Kingdom of Saudi Arabia.
4-1-4	Cybersecurity requirements for third parties shall be periodically reviewed.

Additional implementation requirements — Qayrawan Information Systems

QIS-4-1-1	Third-party staff and contractors are screened before they are given access to data, and current staff are screened retrospectively.
QIS-4-1-2	Every contract includes guarantees that data is deleted securely when the relationship ends or is terminated, with proof provided.
QIS-4-1-3	Every data sharing with a third party is recorded in the data sharing log.
QIS-4-1-4	Data is shared outside the Kingdom only after confirming the receiving party can protect it, obtaining the approval of the authorized person and the controller, and meeting the legal requirements.
QIS-4-1-5	The third party must notify QIS directly of any cybersecurity incident that could affect the data QIS shared with it or that it processes.
QIS-4-1-6	Before sharing, data is reclassified to the lowest level that serves the purpose, using data masking or scrambling.
QIS-4-1-7	Every client contract includes data processing clauses setting purpose, scope, retention, processing location, and duties to notify, return and dispose. QIS uses another party to process a client's data only with the client's prior written approval.

RESTRICTED

Projects of high national sensitivity

Added clause — Qayrawan Information Systems

Drawn from the Data Cybersecurity Controls requirements for third parties on highly sensitive projects, and applied whenever a client classifies a project as such.

QIS-4-1-8	Every QIS employee and third-party member with access to the project's data is screened, and non-disclosure agreements are signed before work starts.
QIS-4-1-9	Project data is processed on devices provided by the client or QIS for this purpose only, inside a closed room with entry and exit control for authorized people only.
QIS-4-1-10	No electronic devices may be brought into the closed room, and no devices, storage media or documents may be taken out of it.

4-2 Cloud Computing and Hosting Cybersecurity

Objective: To ensure proper and efficient remediation of cyber risks and implementation of cybersecurity requirements for cloud computing and hosting, as per the entity's regulatory policies and procedures, relevant legislative and regulatory requirements, orders, and decisions, and to ensure the protection of the entity's information and technology assets on cloud computing services hosted, processed, or managed by third parties.

No.	Controls
4-2-1	Cybersecurity requirements for use of cloud computing and hosting services shall be identified, documented, and approved.
4-2-2	Cybersecurity requirements for the cloud computing and hosting services within the entity shall be implemented.
4-2-3	In accordance with the relevant legislative and regulatory requirements, and in addition to the applicable controls in the Main Domains (1), (2), and (3) and Subdomain (4.1) that are necessary to protect the entity's data or services provided thereto, cybersecurity requirements for use of cloud computing and hosting services shall include the following as a minimum: **4.2.3.1** Protection of entity's data by cloud and hosting service providers in accordance with its classification level and returning data (in a usable format) upon service completion. **4.2.3.2** Separation of the entity's environment (especially virtual servers) from environments of other entities within the cloud computing service provider.
4-2-4	Cybersecurity requirements for cloud computing and hosting services shall be periodically reviewed.

Additional implementation requirements — Qayrawan Information Systems

QIS-4-2-1	Client data is hosted by a cloud provider licensed by the Communications, Space and Technology Commission, in data centres inside the Kingdom only. QIS sets this requirement itself, since the 2024 edition of the controls referred data localization to the National Data Management Office, and bases it on the Office's policies, the regulation on transferring personal data outside the Kingdom, and the government client contracts.
QIS-4-2-2	Each client's environment is separated from other clients' at least logically, and non-production environments are separated from production.
QIS-4-2-3	Client data is returned to the client in a usable format when the contract ends, then removed from QIS's and the provider's environments, with proof of disposal.

9. Alignment with the Personal Data Protection Law

QIS acts as processor for the citizen and student data it handles for its clients, so compliance with the law towards the Saudi Data and AI Authority rests first with the controller, and QIS does what is needed to let the controller meet it. This section summarizes the relevant duties briefly; the law and its implementing regulation are the text to apply.

9.1 Purpose, minimization and retention

9.1.1	Personal data is processed only for the purpose it was collected for, and only as far as that purpose needs.
9.1.2	Personal data is not kept longer than the purpose needs, and is then destroyed or anything identifying its subjects is removed.

Additional implementation requirements — Qayrawan Information Systems

QIS-9.1.1	The retention period for each category of personal data is set in the client contract and in the record of processing activities, and expired data is reviewed every quarter.

9.2 Security of personal data

9.2.1	The controller and the processor take the organizational, administrative and technical measures needed to protect personal data from unauthorized access, disclosure, change or destruction.
9.2.2	The controller chooses a processor that gives sufficient guarantees of applying the law, and checks that it does.

RESTRICTED

Additional implementation requirements — Qayrawan Information Systems

QIS-9.2.1	On request, QIS gives its clients evidence that the controls in this policy are applied, and lets them review them as the contract sets out.

9.3 Reporting personal data breaches

9.3.1	The controller notifies the Saudi Data and AI Authority of a personal data breach within 72 hours of becoming aware of it, as the implementing regulation sets out.
9.3.2	Data subjects are notified of a breach where it could harm them, as the regulation sets out.

Additional implementation requirements — Qayrawan Information Systems

QIS-9.3.1	QIS notifies the controller concerned within 24 hours of discovering any breach affecting its data, so the controller can meet the legal deadline.
QIS-9.3.2	QIS treats every personal data breach as reportable to the controller, without waiting for a harm assessment, applying the stricter rule in the draft amendments to the regulation published for consultation.

9.4 Transferring personal data outside the Kingdom

9.4.1	Personal data may be transferred outside the Kingdom, or disclosed to a party outside it, only in the cases and under the conditions set by the law and the regulation on transferring personal data outside the Kingdom.

Additional implementation requirements — Qayrawan Information Systems

QIS-9.4.1	QIS does not transfer clients' personal data outside the Kingdom in any case, except on a written request from the controller, who takes responsibility for meeting the legal conditions.

9.5 Data subjects' rights

9.5.1	Data subjects have rights under the law, including to be informed about processing, to access their data, and to ask for it to be corrected or destroyed.

Additional implementation requirements — Qayrawan Information Systems

QIS-9.5.1	Requests from data subjects that reach QIS are passed to the controller within two working days, and QIS helps the controller meet them within the legal time limits.

9.6 Impact assessment

9.6.1	An impact assessment of personal data processing is carried out in the cases the regulation sets, including processing that may carry a high risk to data subjects.

RESTRICTED

Additional implementation requirements — Qayrawan Information Systems

QIS-9.6.1	A data protection impact assessment is carried out with the controller before any significant change to the citizen portal or any system that processes personal data.

10. Key performance indicators (KPIs) for data protection

Code	Indicator	Target	Frequency
KPI-01	Hosted systems with their data classification and owner documented	100%	Quarterly
KPI-02	Contracts (new and current) reviewed by GRC that include the security requirements and secure deletion clauses	100%	Monthly
KPI-03	People with access to client data who have a current confidentiality agreement	100%	Monthly
KPI-04	Third-party staff and contractors screened before being given access	100%	Monthly
KPI-05	Data sharings fully recorded and reclassified before sharing	100%	Monthly
KPI-06	Hosted databases encrypted at rest	100%	Quarterly
KPI-07	Ended relationships where proof of return or secure disposal was provided	100%	Quarterly
KPI-08	Data subject requests passed to the controller within two working days	100%	Monthly
KPI-09	Staff and contractors who completed the annual data protection training	95%	Quarterly

11. Key risk indicators (KRIs) for data protection

Colour key (RAG status)

Colour	Status	Meaning and required action
Green	**On target / acceptable**	The indicator is within the acceptable threshold. Routine monitoring continues.
Amber	**Needs attention**	The indicator has passed the acceptable limit and needs

RESTRICTED

Colour	Status	Meaning and required action
		immediate follow-up and correction within the set period.
Red	**At risk / non-compliant**	The indicator has passed the critical threshold and needs immediate escalation to senior management and an urgent treatment plan.

Code	Indicator	Threshold	Frequency
KRI-01	Systems holding Restricted data or higher without a documented classification	Green: 0 · Amber: 1 · Red: 2 or more	Quarterly
KRI-02	Contracts handling QIS or client data without the approved security requirements	Green: 0 · Amber: 1 · Red: 2 or more	Monthly
KRI-03	Third parties or their staff with access to data without screening or a current confidentiality agreement	Green: 0 · Amber: 1 · Red: 2 or more	Monthly
KRI-04	Data sharings without a record or without reclassification	Red: any case	Monthly
KRI-05	Breaches reported to the controller more than 24 hours after discovery	Red: any case	Per incident
KRI-06	Storage or processing locations for client data outside the Kingdom	Red: any case	Quarterly
KRI-07	Non-production environments holding unmasked personal data	Red: any case	Quarterly
KRI-08	Closed-room violations on highly sensitive projects	Red: any case	Weekly

RESTRICTED

12. Consequences of non-compliance

Staff or contractors who do not comply with this policy may face disciplinary action under QIS's internal regulations, including a formal warning, restriction or removal of access, suspension, or termination, depending on how serious the breach is and its impact. Breaches by third parties are handled under the contract and may lead to its termination, without prejudice to legal liability.

13. Contact

Request / report	Responsible party	How to reach them
Questions about the policy	Personal data protection officer	privacy@qis.example
Review of security requirements in a contract	GRC Lead	Procedure 1 in QIS-PRC-001
Request to share data with a third party	Data owner	Procedure 2 in QIS-PRC-001
Reporting an actual or suspected breach	Security Operations and Engineering	security@qis.example — ext. 2100
Request from a data subject	Personal data protection officer	privacy@qis.example

14. Review and update

14.1 Review

The GRC Lead reviews this policy at least once a year to confirm it is still suitable and effective, and reports the results to the Cybersecurity Steering Committee.

14.2 Update

This policy is updated when the applicable laws and regulations change, including when the amendments to the implementing regulation of the Personal Data Protection Law are issued in final form, when QIS's services or clients change, or after a significant data incident.

RESTRICTED

15. References

Type	Code	Reference	Issuer
External	ECC-2:2024	Essential Cybersecurity Controls — basis of section 8	National Cybersecurity Authority
External	DCC-1:2022	Data Cybersecurity Controls	National Cybersecurity Authority
External	PDPL	Personal Data Protection Law and its implementing regulation — basis of section 9	Saudi Data and AI Authority

Type	Code	Reference	Issuer
External	—	Regulation on transferring personal data outside the Kingdom	Saudi Data and AI Authority
External	—	National data management policies and standards (data localization and protection)	National Data Management Office
Internal	QIS-PRC-001	Data Protection Procedure	QIS
Internal	QIS-PRF-001	Company Profile and Scope	QIS
Internal	QIS-RR-001	Risk Register (R-01, R-05, R-14)	QIS
Internal	QIS-IRP-001	Incident Response Plan	QIS
Internal	QIS-POL-002	AI Usage Policy	QIS

The objectives and controls in section 8 are quoted word for word from the official English text of the Essential Cybersecurity Controls (ECC-2:2024), checked on 11 November 2026. Where the English and Arabic texts of the controls differ, the Arabic text prevails: NCA's Arabic 2-8-3-3 also requires encryption during processing. The summaries of the law in section 9 must be matched against the official texts before version 1.0 is approved.

RESTRICTED